

Narrativa explicativa de la Encuesta ISO 27001 sobre Indicadores y Métricas

1. De la intuición al dato (y vuelta)

Todo CISO veterano conoce la escena: el comité de dirección pregunta “¿estamos seguros?” y uno, entre estoico y pragmático, responde con una combinación de experiencia, gráficos y un ligero temblor en el párpado. La norma ISO/IEC 27001:2022, con su insistencia en la monitorización y la medición, viene a recordar que esa respuesta debería apoyarse menos en la intuición y más en indicadores que muestren si el SGSI hace lo que promete. [web:1][web:33]

Esta encuesta nace precisamente ahí: en la distancia –a menudo considerable– entre lo que creemos medir y lo que realmente medimos. Entre el KPI que luce espléndido en una presentación y la métrica que, en un informe de auditoría, se muestra obstinadamente sincera. [web:13]

2. ¿Qué queremos averiguar?

El cuestionario no pretende pillar a nadie en falta, sino mapear con cierto cariño crítico cómo las organizaciones están usando (o dejando de usar) los indicadores de seguridad. Tanto si la entidad está certificada en ISO 27001 como si simplemente coquetea con la norma, el foco está en cinco grandes cuestiones:

1. ¿Existe un sistema de indicadores mínimamente serio o reina el Excel improvisado?
2. ¿Los indicadores se derivan de objetivos claros o se acumulan como cromos?
3. ¿Miden solo el pasado (incidentes) o también factores que anticipan el futuro (riesgos, formación, higiene, resiliencia)? [web:31][web:33]
4. ¿Dialogan con el ecosistema regulatorio y con los datos que producen actores como INCIBE o ENISA? [web:12][web:16]
5. ¿Influyen de verdad en decisiones de negocio, o viven en un PowerPoint perpetuo?

Las respuestas a estas preguntas permiten entender no solo el estado del arte, sino también hacia dónde evoluciona la práctica de medición en seguridad en España y en el entorno europeo.

3. De ISO 27001 a NIS2, pasando por la realidad

ISO/IEC 27001:2022 pide medir, pero deja margen para que cada organización decida qué medir exactamente. ISO/IEC 27004 y las guías de ISACA rellenan parte del vacío, ofreciendo estructuras para definir sistemas de KPIs que cubran controles, riesgos, eficacia y eficiencia. [web:13][web:33][web:34]

Mientras tanto, el mundo regulatorio se ha puesto interesante: NIS2, GDPR, DORA y compañía han elevado el listón de lo que se espera de las métricas de ciberseguridad, sobre todo en sectores críticos. [web:22][web:20] Los informes de actividad de INCIBE y los análisis de ENISA añaden, año tras año, estadísticas de incidentes y vulnerabilidades que actúan como “espejo” para las organizaciones: si el país ve subir un 26 % los incidentes y multiplicarse las detecciones de sistemas vulnerables, quizá ha llegado

el momento de que nuestros indicadores internos digan algo más sofisticado que “hemos tenido dos incidentes y un susto”. [web:12][web:16]

La encuesta intenta conectar esos dos mundos: la norma y la regulación, por un lado, y las prácticas concretas de indicadores en empresas y administraciones, por otro.

4. Qué cuenta (y qué no) como buen indicador

Entre las muchas virtudes que se atribuyen a un buen indicador, esta encuesta se fija especialmente en algunas:

- Que tenga un vínculo claro con un objetivo de seguridad o de negocio.
- Que se pueda medir sin sacrificar tres equipos humanos y la paz familiar.
- Que cambie con el tiempo de manera significativa (es decir, que no sea un 100 % permanente por diseño).
- Que permita tomar decisiones: priorizar inversiones, ajustar controles, cambiar procesos. [web:13][web:31]

Un indicador que solo existe porque “lo pide la auditoría” es un candidato serio a jubilación anticipada. Un indicador que provoca debates útiles en el comité de dirección merece, en cambio, permanecer aunque no sea perfecto.

5. Cómo leer la encuesta desde dentro

Para quien la rellena desde una organización concreta, la encuesta puede leerse como un espejo razonablemente honesto. Si uno se descubre respondiendo demasiados “no”, “en preparación” o “nos gustaría”, no es necesariamente mala señal: significa que hay espacio para una estrategia de indicadores más madura, estructurada y útil.

Puede ser útil considerar:

- ¿Cuántos indicadores actuales son realmente consumidos por alguien que decide?
- ¿Cuántos miden cosas que, si cambian, desencadenan acciones concretas?
- ¿Hasta qué punto los indicadores se han adaptado a la transición a ISO 27001:2022 (nuevos controles, enfoque de riesgo, etc.)? [web:1][web:32]

6. Qué puede ganar la organización

La recompensa de tomarse en serio esta encuesta no es solo un bonito autodiagnóstico. Es, sobre todo:

- Detectar redundancias (indicadores que no aportan valor).
- Identificar vacíos (áreas críticas sin métricas razonables).
- Alinear el lenguaje interno con el de reguladores, auditores y marcos de referencia. [web:13][web:20][web:22]
- Preparar el terreno para cuadros de mando más integrados, donde lo técnico y lo estratégico dejen de vivir en universos paralelos.

En el mejor de los casos, la organización saldrá con una lista corta pero clara de mejoras priorizadas: añadir ciertos indicadores, automatizar otros, revisar definiciones, integrar métricas económicas, o ajustar la frecuencia de reporte.

7. Qué puede ganar el ecosistema (sector, país, Unión)

Visto desde fuera, los resultados agregados pueden informar políticas públicas, estrategias nacionales y planes sectoriales. Si descubrimos, por ejemplo, que la mayoría de operadores esenciales miden incidentes pero casi ninguno tiene indicadores sólidos de resiliencia o de terceros, no hace falta mucha imaginación para ver la agenda de mejora. [web:16][web:20][web:26]

La estandarización de la medición –con ISO 27001 y 27004 como hilo conductor, y NIS2 como contexto regulatorio– permite comparar sin caer en simplismos: no se trata de publicar rankings de “ciberseguro del año”, sino de identificar patrones, brechas y buenas prácticas transferibles entre sectores y países. [web:13][web:24][web:26]

8. Una invitación (amablemente irónica)

La encuesta no pretende demostrar que todas las organizaciones miden mal, sino animarlas a medir mejor. Es, en cierto modo, una invitación a que el discurso sobre “gestión basada en datos” deje de ser un eslogan de presentación y se materialice en indicadores que conecten la teoría ISO con la realidad cotidiana.

Si después de todo ello se consigue que la próxima vez que alguien pregunte “¿estamos seguros?” la respuesta incluya menos silencios incómodos y más datos relevantes, la encuesta habrá cumplido su función. Y si, además, sirve para que unos cuantos indicadores inútiles desaparezcan discretamente del cuadro de mando, tanto mejor.